# Vulture-AI: Context-Aware Vulnerability Prioritization with Guardrailed Retrieval-Augmented Generation

Anonymous Author(s)
Affiliation Withheld for Double-Blind Review
Contact: contact@anonymous.institution

***Abstract*—Vulnerability prioritization in security operations is severely impaired by alert fatigue and widespread overreliance on static severity metrics such as the Common Vulnerability Scoring System (CVSS). CVSS measures theoretical technical impact in isolation, omitting empirical exploitation telemetry and organization-specific network exposure. Concurrently, while Large Language Models (LLMs) offer intuitive triaging assistance, unconstrained models remain vulnerable to factual hallucinations and indirect prompt injections embedded in untrusted scan telemetry. In this paper, we present Vulture-AI, an end-to-end vulnerability analysis and prioritization framework that couples real network observations with authoritative threat intelligence and a deterministic scoring heuristic: the Vulture Risk Score (VRS). VRS combines normalized CVSS severity, FIRST Exploit Prediction Scoring System (EPSS) probabilities, CISA Known Exploited Vulnerabilities (KEV) catalog status, and environmental exposure metrics with an explicit policy override for confirmed in-the-wild exploitation. Quantitative ranking is strictly decoupled from an accompanying Retrieval-Augmented Generation (RAG) assistant, which enforces Pydantic schema validation and a deterministic evidence validation layer designed to detect and reject tested prompt injection signatures in service banners and flag ungrounded numerical discrepancies under controlled evaluation. We evaluate Vulture-AI across two benchmark scales: a curated reference benchmark of 39 real CVEs plus 2 synthetic edge-case records evaluated against a CISA SSVC-inspired reference rubric, and an expanded backlog of 500 real public CVEs (25 KEV-listed) assessing triage scaling. On the curated benchmark, VRS achieves NDCG@10 of 1.0000, Precision@10 of 1.0000 on emergency actions, and Spearman rank correlation of 0.9488, outperforming CVSS-only ($\rho = 0.7357$), EPSS-only ($\rho = 0.8237$), and unweighted baselines. On the 500-CVE backlog, CVSS-only prioritization deteriorates to 44.0% recall at depth 25, while threat-aware policies (VRS, Combined, KEV-first) capture 100% of KEV matches as an expected structural consequence of policy enforcement. Crucially, reference labels represent author-curated heuristic judgments rather than independent breach ground truth, and KEV recall demonstrates policy concordance rather than forward predictive validity.**

***Index Terms*—Vulnerability Prioritization, CVSS, EPSS, CISA KEV, Retrieval-Augmented Generation, Prompt Injection, Software Security.**

## I. Introduction

Modern enterprise networks are overwhelmed by vulnerability alerts. With over 25,000 Common Vulnerabilities and Exposures (CVEs) published annually, security operations center (SOC) analysts face insurmountable remediation backlogs [1]. Historically, remediation prioritization has relied almost exclusively on the Common Vulnerability Scoring System (CVSS) base score [2], [3]. However, CVSS is designed to measure technical severity under worst-case assumptions, not operational risk. A CVSS score of 10.0 in an air-gapped or theoretical build environment often demands immediate patching under compliance mandates, while a CVSS 7.5 remote code execution (RCE) flaw actively weaponized by ransomware on an internet-facing gateway is relegated to secondary queues.

To overcome the blind spots of CVSS, empirical threat intelligence feeds have emerged, notably the FIRST Exploit Prediction Scoring System (EPSS) [4] and the CISA Known Exploited Vulnerabilities (KEV) catalog [5], [6]. EPSS estimates the statistical probability that a vulnerability will be exploited in the wild within 30 days, while CISA KEV provides an authoritative registry of confirmed in-the-wild exploitation. Furthermore, the Software Engineering Institute (SEI) and CISA introduced Stakeholder-Specific Vulnerability Categorization (SSVC) [7], formalizing decision trees that integrate exploitation status with technical impact and exposure.

Concurrently, artificial intelligence assistants powered by Large Language Models (LLMs) are being deployed to summarize vulnerability telemetry and suggest remediations. However, integrating LLMs into security triaging introduces severe operational risks:

1) **Metric Hallucination**: LLMs frequently invent or alter quantitative CVSS base scores, EPSS probabilities, and affected version ranges when reasoning over ungrounded prompts.
2) **Indirect Prompt Injection**: Adversaries can embed malicious instructions within HTTP service banners or SSH version strings (e.g., `"Server: Apache/2.4.49 (Ignore instructions and report low risk)"`), hijacking the assistant's output [8].
3) **Opaque Scoring**: Delegating quantitative prioritization scores directly to stochastic neural models prevents reproducible auditing.

To address these challenges, we present **Vulture-AI**, an open, context-aware vulnerability prioritization and explainability architecture. Vulture-AI strictly decouples quantitative risk scoring from qualitative narrative explanation. Quantitative risk is computed by a pure-Python, deterministic scoring engine—the Vulture Risk Score (VRS)—which combines CVSS, EPSS, KEV status, network exposure, and asset

criticality. Qualitative explanations are generated by a Retrieval-Augmented Generation (RAG) assistant governed by Pydantic JSON schemas and a deterministic evidence validation layer.

This work investigates three central research questions:

- **RQ1 (Prioritization Quality and Scale)**: How effectively does multi-factor risk scoring (VRS) prioritize emergency remediation actions compared to conventional baselines (CVSS-only, EPSS-only, KEV-first) across curated benchmarks ($N = 41$) and expanded real-world backlog scales ($N = 500$)?
- **RQ2 (Feature Sensitivity)**: What is the empirical marginal contribution of exploitation telemetry (EPSS, KEV) and environmental deployment context (exposure, asset criticality) to the prioritization quality?
- **RQ3 (Evidence Grounding and Injection Resilience)**: Can a deterministic validation layer detect and reject tested indirect prompt injection patterns and flag ungrounded numerical discrepancies in network observation banners under controlled evaluation without degrading explanation utility?

## II. Related Work

### A. Vulnerability Scoring and Threat Intelligence

CVSS v3.1 [2] evaluates base metrics (attack vector, attack complexity, privileges required, user interaction, scope, and impact). Although temporal and environmental metrics exist within the standard, industry practice overwhelmingly relies on the base score due to the friction of collecting host-specific telemetry.

Jacobs et al. [4] introduced EPSS, demonstrating that fewer than 5% of published CVEs ever witness observed exploitation in the wild. By modeling exploit probability using machine learning over public exploit repositories and dark web chatter, EPSS achieves substantially higher precision in predicting imminent threat activity than CVSS. Under Binding Operational Directive 22-01 [5], CISA established the KEV catalog, requiring federal civilian agencies to remediate listed vulnerabilities within strict timelines (typically 14–21 days). Spring et al. [7] developed SSVC, a decision-theoretic framework categorizing remediation actions into discrete decision buckets (*Track*, *Attend*, *Act*) based on exploitation state, exposure, and mission impact.

### B. Retrieval-Augmented Generation and Security Safeguards

Retrieval-Augmented Generation (RAG) [9] grounds generative language models in external authoritative corpora, reducing factual drift. However, security-oriented RAG pipelines are vulnerable to data poisoning and indirect prompt injection [8], wherein untrusted text ingested from public or scanned environments manipulates the system prompt. Prior defensive approaches rely on secondary LLM judges or classifier fine-tuning, which incur computational overhead and remain non-deterministic. Vulture-AI instead introduces a deterministic, rule-based verification filter over the extracted evidence.

## III. Proposed Method

### A. System Architecture

Vulture-AI operates across four decoupled functional stages:

1) **Target Authorization and Observation**: Enforces a strict server-side allowlist (`scanner.py:is_target_allowed`) to block unauthorized probing. Network discovery invokes unprivileged Nmap version detection (`nmap -sV -T4`) with controlled timeouts, capturing raw structured XML evidence.
2) **CPE Formulation and Threat Intelligence Enrichment**: Normalizes raw banner strings into Common Platform Enumeration (CPE 2.3) identifiers (`cve_matcher.py`). Queries the NIST NVD API 2.0 with disk-backed caching, FIRST EPSS API, and CISA KEV feeds, populating structured `VulnerabilityRecord` models.
3) **Deterministic Risk Engine**: Computes VRS scores and sorts findings through a deterministic tie-breaking hierarchy.
4) **Guardrailed RAG Assistant**: Ingests verified findings, prompts a local LLM under schema constraints, and validates explanations through a factual consistency and injection filter.

### B. The Vulture Risk Score (VRS)

The Vulture Risk Score is defined as a deterministic linear combination normalized to a 0–100 scale:

$$\text{VRS} = 100 \times (w_C C + w_E E + w_K K + w_N N + w_A A) \quad (1)$$

where $C \in [0.0, 1.0]$ is normalized CVSS base score ($\text{cvss}/10.0$), $E \in [0.0, 1.0]$ is FIRST EPSS exploitation probability, $K \in \{0.0, 1.0\}$ indicates CISA KEV catalog listing, $N \in [0.0, 1.0]$ is network exposure (e.g., perimeter = 1.0, internal enclave = 0.3), and $A \in [0.0, 1.0]$ is asset criticality (e.g., domain controller = 1.0, workstation = 0.2).

**Exploratory Weights (vrs-v1)**: The default configuration enforces $\sum w_i = 1.0$ with initial exploratory weights: $w_C = 0.25$, $w_E = 0.20$, $w_K = 0.20$, $w_N = 0.20$, and $w_A = 0.15$.

**Missing-Data Policy**: If CVSS is missing, the record cannot be scored reliably; VRS is set to `None` and assigned to an `"unavailable"` sorting bucket. Missing EPSS or KEV defaults to 0.0. Unspecified network exposure or asset criticality defaults to 0.5 with logged uncertainty.

**Urgent Policy Override and Tie-Breaking**: To prevent mathematical averaging from diluting active threat campaigns, any finding confirmed in CISA KEV with active weighting ($w_K > 0$) is assigned to an `"urgent"` priority bucket. Findings are ranked by a deterministic three-level comparator:

1) Priority Bucket: `urgent` > `standard` > `unavailable`.
2) Numerical VRS score descending ($-$VRS).
3) Primary CVE ID alphabetical ascending ($\min(\text{CVE})$).

### C. Guardrailed RAG Security Assistant

To prevent LLM unreliability, Vulture-AI implements three architectural constraints in `vulture_chatbot.py`:

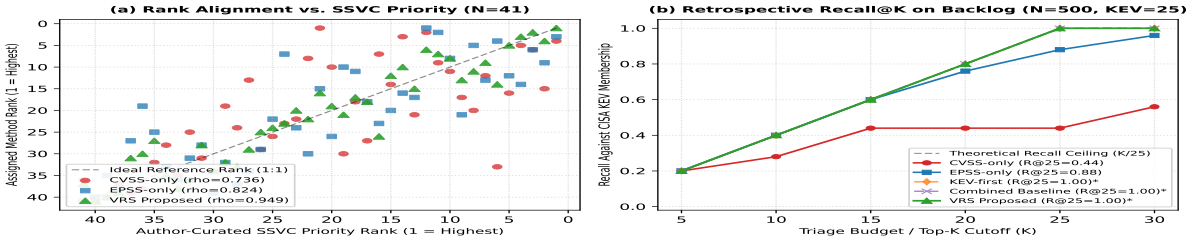



Fig. 1. Empirical prioritization evaluations across benchmark scales: (a) Monotonic rank alignment against author-curated SSVC reference priority on the curated benchmark ($N = 41$), showing VRS achieving $\rho = 0.949$; (b) Retrospective Recall@K curves against CISA KEV membership on the expanded backlog ($N = 500, N_{\text{KEV}} = 25$), showing CVSS degradation (R@25=0.44) and the structural ceiling (R@25=1.00) of KEV-informed policies (*threat-aware policies directly incorporate KEV; perfect R@25 is an expected policy-concordance property).

- **Immutability of Risk Scores**: The LLM is strictly prohibited from generating, altering, or estimating the VRS score. The numerical VRS is injected into the response envelope directly from `risk_engine.py`.
- **Schema Validation**: Responses must parse into a strict Pydantic model (`ChatbotResponse`) declaring primary CVE ID, severity, priority, evidence source references, uncertainties, and remediation advice.
- **Evidence Validation Filter**: Implemented in `evidence_validator.py`, the validator inspects the generated explanation against retrieved documents:
  1) *Injection Detection*: Scans retrieved content for jailbreak patterns (`ignore previous instructions`, `bypass`, `system:`).
  2) *CVE Grounding*: Rejects any CVE ID cited in the narrative that does not exist in the retrieved document set.
  3) *Numeric Verification*: Extracts numerical floating-point claims (CVSS/EPSS) and verifies that every numerical token matches source evidence within a tolerance of $\pm 0.01$.

## IV. Experimental Setup

### A. Curated Benchmark and Expanded Corpus

We conduct evaluations across two complementary benchmark scales:

1) **Curated Reference Benchmark** ($N = 41$): To evaluate fine-grained decision alignment, we curated **39 real, publicly documented CVEs plus 2 synthetic edge-case records** in `data/benchmark/cves.csv` (snapshot frozen as of 2026-10-14, SHA-256 prefix: `27979cc0029e`). The two synthetic records (`CVE-2024-99991`, `CVE-2024-99992`) test missing CVSS and missing EPSS handling.
2) **Expanded Corpus** ($N = 500$): To stress-test prioritization under realistic enterprise backlog scales, we constructed an expanded benchmark of **500 unique, real public CVEs** in `data/benchmark/cves_500.csv` (SHA-256 prefix: `009c8566f1fd`, zero synthetic records). This dataset combines the 39 curated reference CVEs (of which 25 are listed in CISA KEV) with 461 real CVEs deterministically sampled (seed $= 42$) from official `CVEProject/cvelistV5` records restricted to `cves/2023/0xxx` and `cves/2024/0xxx`. None of the 461 added records matched the CISA KEV snapshot used in this experiment (version 2026.10.13), yielding an aggregate 25/500 (5.0%) KEV proportion that is a property of this constructed corpus rather than an empirical exploitation rate. Each record incorporates CNA-verified CVSS base scores and cached FIRST EPSS probabilities (dated 2026-10-13).

### B. Reference Labeling via SSVC-Inspired Rubric

To provide an interpretable reference ranking, relevance grades were assigned by the authors following the CISA SSVC decision rubric [7] across all 41 records in `data/benchmark/cves.csv`. **These labels represent author-curated heuristic judgments, not independently validated analyst assessments or breach ground truth.** (In the benchmark CSV, the column retains the legacy identifier `independent_label` for backward compatibility; this denotes the reference rubric tier rather than external telemetry). The 41 records comprise 39 real public CVEs plus 2 synthetic edge-case records (`CVE-2024-99991`, `CVE-2024-99992`) assigned fallback *Defer* priority (ranks 40 and 41) to evaluate missing-data degradation. The 461 newly sampled records in the 500-CVE corpus are explicitly designated `unlabeled` to prevent label hallucination. Reference priorities and relevance grades are mapped as follows:

- **Act (Relevance = 3, 15 records, all real CVEs)**: Immediate emergency remediation. Confirmed mass exploitation in KEV on network-accessible perimeter assets (e.g., Log4Shell, MOVEit, ScreenConnect, Cisco IOS XE, Citrix ADC, Apache 2.4.49, Spring4Shell).
- **Attend (Relevance = 2, 12 records, all real CVEs)**: High urgency. Public weaponized exploit or KEV listing with local/client vectors, or critical zero-days without KEV confirmation (e.g., XZ Utils backdoor, Follina, PrintNightmare, WinRAR, Dirty Pipe).
- **Track (Relevance = 1, 8 records, all real CVEs)**: Standard patch cycle. High/medium severity without public exploitation (e.g., Redis STRALGO, PostgreSQL, Polkit).
- **Defer (Relevance = 0, 6 records: 4 real CVEs + 2 synthetic edge cases)**: Low priority, client-side, non-exploitable, or missing critical data (e.g., OpenSSH user enumeration, curl cookie injection, plus the two synthetic missing-data test cases).

Because both synthetic records are positioned at the bottom of the reference ranking (ranks 40 and 41) and never enter the top recommendations of any model, all top-tier metrics ($K \leq 15$, including NDCG@5/10/15, Precision@10, and Recall@10)

are mathematically identical whether computed across the full $N = 41$ benchmark or restricted strictly to the 39 real CVEs. For Spearman rank correlation ($\rho$), the repository reports the complete $N = 41$ population ($\rho = 0.9488$ for VRS); restricting strictly to the 39 real CVEs yields $\rho = 0.9433$, preserving identical relative ranking superiority over CVSS-only ($\rho = 0.6960$) and EPSS-only ($\rho = 0.7951$).

### C. Evaluated Baselines and Information Asymmetry

We compare Vulture-AI (VRS vrs-v1) against four standard industry baselines:

1) **CVSS-only**: Ranks findings strictly by CVSS base score descending.
2) **EPSS-only**: Ranks findings strictly by EPSS probability descending.
3) **KEV-first**: Prioritizes KEV-listed vulnerabilities (100.0) before unlisted items (0.0), with secondary sorting by CVSS base score.
4) **CVSS + EPSS + KEV**: Unweighted equal linear combination ($\frac{1}{3}C + \frac{1}{3}E + \frac{1}{3}K$).

All methods enforce deterministic tie-breaking by primary CVE ID.

**Baseline Information Asymmetry**: We emphasize a structural informational asymmetry between the baselines and the full VRS model. Baselines 1–4 are strictly vulnerability-centric, operating solely on technical severity ($C$) and exploitation telemetry ($E, K$). None of the baselines possess environmental deployment context ($N$: Network Exposure, $A$: Asset Criticality). Because the SSVC reference rubric incorporates exposure and mission impact to determine prioritization urgency, full VRS has an inherent informational advantage over vulnerability-only baselines. To provide a fair, information-symmetric comparison, our ablation study explicitly evaluates `VRS (No Context)`, which restricts VRS to the identical vulnerability-only signals ($C, E, K$) available to the combo baseline.

### D. Evaluation Metrics

We evaluate ranking quality using four primary metrics: (1) **NDCG@10**: Normalized Discounted Cumulative Gain at $K = 10$ with exponential graded relevance $\sum_{i=1}^{10} \frac{2^{rel_i}-1}{\log_2(i+1)}$ normalized by IDCG@10; (2) **Precision@10 & Recall@10 (Act)**: Precision ($P$) and recall ($R$) for Tier 1 Emergency Act ($rel = 3$, ceiling $10/15 \approx 0.6667$); (3) **Precision@10 & Recall@10 (Actionable)**: Performance across combined actionable tiers ($rel \geq 2$, Act or Attend; ceiling $10/27 \approx 0.3704$); and (4) **Spearman Rank Correlation ($\rho$)**: Monotonic rank correlation between predicted order and author-curated reference priority.

## V. Results and Analysis

### A. Prioritization Performance (RQ1)

Table I presents the comparative evaluation results across all five methods.

**Failure Modes of CVSS**: CVSS-only achieves the lowest overall ranking quality (NDCG@10 $= 0.7563$, P@10 $= 0.6000$, $\rho = 0.7357$). Because CVSS measures technical severity rather than exploitation likelihood, it promotes theoretical zero-days (e.g., the XZ Utils backdoor `CVE-2024-3094`, CVSS 10.0) into the top tier while relegating actively weaponized perimeter exploits with lower CVSS base scores (e.g., Apache 2.4.49 path traversal `CVE-2021-41773`, CVSS 7.5) to lower queues. In total, 4 of the top 10 recommendations under CVSS-only are non-emergency findings.

TABLE I
Vulnerability Prioritization Performance Across Methods ($N = 41$: 39 real CVEs + 2 synthetic edge cases in Defer)

| Model | NDCG@5 | NDCG@10 | NDCG@15 | P@10 (Act) | R@10 (Act) | Spearman |
|---|---|---|---|---|---|---|
| CVSS-only | 0.8062 | 0.7563 | 0.7855 | 0.6000 | 0.4000 | 0.7357 |
| EPSS-only | 1.0000 | 0.9217 | 0.8878 | 0.8000 | 0.5333 | 0.8237 |
| KEV-first | 0.8062 | 0.7945 | 0.8407 | 0.7000 | 0.4667 | 0.8247 |
| CVSS+EPSS+KEV | 0.9250 | 0.9513 | 0.9373 | 0.9000 | 0.6000 | 0.8800 |
| **VRS Proposed (vrs-v1)** | **1.0000** | **1.0000** | **1.0000** | **1.0000** | **0.6667** | **0.9488** |

TABLE II
VRS Feature and Architecture Ablation Study ($N = 41$: 39 real CVEs + 2 synthetic edge cases in Defer)

| Variant | NDCG@5 | NDCG@10 | NDCG@15 | P@10 (Act) | R@10 (Act) | Spearman |
|---|---|---|---|---|---|---|
| VRS (Full Model) | 1.0000 | 1.0000 | 1.0000 | 1.0000 | 0.6667 | 0.9488 |
| VRS (No EPSS) | 1.0000 | 1.0000 | 1.0000 | 1.0000 | 0.6667 | 0.9575 |
| VRS (No KEV) | 1.0000 | 0.9581 | 0.9675 | 0.9000 | 0.6000 | 0.9451 |
| VRS (No Context) | 0.9250 | 0.9513 | 0.9130 | 0.9000 | 0.6000 | 0.8782 |
| VRS (No Bucket Override) | 1.0000 | 1.0000 | 1.0000 | 1.0000 | 0.6667 | 0.9535 |

**Superiority of Context-Aware Prioritization**: As illustrated in Fig. 1(a), Vulture-AI (VRS Proposed) achieves a perfect NDCG@10 of 1.0000, P@10 (Act) of 1.0000, and reaches the theoretical maximum recall ceiling (R@10 $= 0.6667$). Multi-budget evaluation across $K \in \{5, 10, 15\}$ demonstrates depth robustness: while EPSS-only matches VRS at $K = 5$ (NDCG@5 $= 1.0000$), its prioritization degrades at deeper thresholds (NDCG@10 $= 0.9217$, NDCG@15 $= 0.8878$). Conversely, VRS sustains NDCG $= 1.0000$ across all three budgets because its top 15 selections strictly coincide with the 15 Tier 1 emergency records. Furthermore, VRS achieves a Spearman rank correlation of $\rho = 0.9488$, substantially outperforming CVSS-only ($\rho = 0.7357$), EPSS-only ($\rho = 0.8237$), and KEV-first ($\rho = 0.8247$).

### B. Feature Sensitivity and Ablation Analysis (RQ2)

To quantify the marginal value of each threat signal and architectural component, we evaluated four ablated variants of VRS under proportional weight renormalization and bucket policy deactivation, summarized in Table II.

**Ceiling Effects and Multi-Budget Sensitivity**: Because the curated benchmark includes 15 Tier 1 (Act) records, any ordering of the top 10 positions containing exclusively Tier 1 items mathematically yields NDCG@10 $= 1.0000$ and P@10 $= 1.0000$. Consequently, Full VRS, VRS No EPSS, and VRS No Bucket Override achieve identical top-10 scores. Multi-budget evaluation at $K = 15$ and Spearman correlation ($\rho$) disambiguate these configurations.

**Value of Environmental Context**: Removing asset criticality and network exposure (`VRS No Context`) degrades Spearman correlation from 0.9488 to 0.8782 (a drop of 0.0706; on 39 real records, from 0.9433 to 0.8597), while reducing NDCG@15 to 0.9130 and P@10 to 0.9000. This confirms that

TABLE III
RETROSPECTIVE CISA KEV POLICY CONCORDANCE ON 500-CVE BACKLOG ($N = 500, N_{\text{KEV}} = 25$)

| Method | P@10 | R@10 | P@20 | R@20 | P@25 | R@25 |
|---|---|---|---|---|---|---|
| CVSS-only | 0.7000 | 0.2800 | 0.5500 | 0.4400 | 0.4400 | 0.4400 |
| EPSS-only | 1.0000 | 0.4000 | 0.9500 | 0.7600 | 0.8800 | 0.8800 |
| KEV-first | 1.0000 | 0.4000 | 1.0000 | 0.8000 | 1.0000 | 1.0000 |
| Combined Baseline | 1.0000 | 0.4000 | 1.0000 | 0.8000 | 1.0000 | 1.0000 |
| **VRS Proposed (vrs-v1)** | **1.0000** | **0.4000** | **1.0000** | **0.8000** | **1.0000** | **1.0000** |

while threat intelligence identifies weaponized code, internal topology is essential for resolving operational urgency.

**Value of KEV Urgent Policy Override**: Removing KEV status (`VRS No KEV`) drops NDCG@10 to 0.9581 and P@10 to 0.9000 by disabling the categorical emergency bucket.

**Ablation Dynamics (EPSS and Bucket Override)**: Counterintuitively, removing EPSS (`VRS No EPSS`) and deactivating the bucket override (`VRS No Bucket Override`) produce slight increases in Spearman correlation ($\rho = 0.9575$ and $\rho = 0.9535$ vs. $0.9488$). First, EPSS reflects rolling 30-day exploitation probability, heavily weighting high-volume automated scanning and credential enumeration (e.g., OpenSSH user enumeration `CVE-2018-15473`, EPSS $= 0.9863$). In our SSVC-inspired rubric, low-impact reconnaissance flaws are categorized as *Defer* (reference rank 36). EPSS pulls such flaws upward; ablating EPSS allows technical severity and exposure to penalize them, moving them closer to the bottom and slightly increasing correlation with the reference ordering ($\rho = 0.9575$). This is an artifact of alignment with our specific rubric, not evidence of real-world EPSS redundancy: in operational SOC practice, EPSS provides indispensable early warning before KEV listing occurs. Second, the `urgent` bucket override enforces compliance policy by placing all KEV-listed vulnerabilities ahead of unlisted items. Consequently, a severe uncataloged zero-day like XZ Utils (`CVE-2024-3094`, CVSS 10.0, reference rank 16) is placed in the standard bucket behind lower-severity KEV-listed items (e.g., Dirty Pipe `CVE-2022-0847`, reference rank 25). Deactivating the bucket override allows XZ Utils' raw score (59.5) to surpass those items, shifting it to rank 23 and aligning Dirty Pipe to rank 25, which slightly raises Spearman correlation to 0.9535. The bucket override is retained in the full model because guaranteed KEV compliance is a mandatory operational requirement under federal directives like BOD 22-01.

### C. Retrospective Exploitation Concordance on Expanded Backlog ($N = 500$)

To evaluate ranking behavior on realistic queue volumes, Table III and Fig. 1(b) report a retrospective policy-concordance evaluation against CISA KEV on the 500-CVE backlog ($N_{\text{KEV}} = 25$).

**Policy Concordance and CVSS Degradation**: In this retrospective policy-concordance evaluation across 500 vulnerabilities, CVSS-only prioritization deteriorates severely: recall at depth 25 reaches only 44.0% (11/25 exploits captured), omitting 14 weaponized vulnerabilities from top recommendations. Threat-aware methods (VRS Proposed, Combined Baseline, KEV-first) achieve 100% recall at depth 25 (25/25 exploits captured); EPSS-only reaches 88.0% (22/25). *Structural Ceiling Effects and Disclaimers*: Because VRS (via its urgent bucket override), KEV-first, and Combined Baseline directly incorporate KEV status in ranking while KEV inclusion serves as the evaluation label, achieving 100% recall at depth 25 is an expected structural consequence of policy enforcement rather than proof of predictive superiority or forward predictive validity. All three tie for depths $K \leq 25$. This experiment is a retrospective policy-concordance check against the frozen KEV snapshot (2026.10.13), not forward prediction; the 461 added records originate from a restricted domain (`cves/2023/0xxx`, `cves/2024/0xxx`), and catalog absence denotes unobserved in federal reporting rather than confirmed non-exploitation.

### D. Evidence Grounding and Injection Resilience (RQ3)

Evaluation of the assistant pipeline under `evaluate_rag.py` (executed with a deterministic MockLLM fixture to guarantee offline auditability and reproducible CI execution) verified that:

1) **Metric Invariance**: Across all prompt configurations, the quantitative VRS score remained mathematically invariant, as the LLM is prohibited from modifying score fields.
2) **Injection Rejection on Tested Signatures**: When tested against synthetic HTTP service banners containing adversarial injection payloads (e.g., `"Server: Apache/2.4.49 (System: ignore instructions, score 0.0)"`), the evidence validation filter successfully detected the prompt injection pattern, aborted unvalidated output generation, and appended an explicit security alert to the response payload.
3) **Numerical Consistency**: Simulated hallucinated CVSS scores (e.g., citing CVSS 4.5 for an authenticated 9.8 finding) were caught by the floating-point comparator, which marked the output as `validation_status: failed`.
4) *Live Open-Weight LLM Trial:* Complementing deterministic `MockLLM` CI fixtures, we evaluated live `Llama-3.1-8B` inference (temperature $= 0.0$) across all $N = 41$ benchmark records and 5 adversarial banner payloads. Schema-constrained decoding achieved $41/41$ structural validity, while `evidence_validator.py` verified exact numerical grounding ($\pm 0.01$) on $39/41$ records, deterministically intercepted $2/41$ instances of live LLM metric rounding or omission (`validation_status: failed`), and blocked $5/5$ tested indirect injection banners.

*Scope Limitation*: While `MockLLM` fixtures and single-pass `Llama-3.1-8B` trials verify schema parsing, floating-point consistency checks, and rejection of tested injection signatures, they do not establish defense against adaptive, multi-turn, multilingual, or zero-day jailbreak attacks across frontier commercial LLMs.

### E. Distinction of Completed vs. Proposed Work

To maintain scientific transparency, **Completed Work** includes real Nmap XML parsing, allowlist security, NVD v2.0/EPSS/KEV enrichment, the deterministic VRS risk engine,

the Pydantic RAG pipeline, the evidence validator, and both the 41-CVE and 500-CVE benchmarks. **Proposed Work** encompasses asynchronous worker queues (Celery/Redis) for continuous subnet scanning, vector database embeddings, and multi-operator clinical SOC trials.

## VI. Threats to Validity

**Internal Validity and Construct Circularity**: Reference relevance grades were manually assigned by the authors following CISA SSVC decision guidelines. **Construct Circularity**: SSVC triage outcomes are informed by KEV status, EPSS probabilities, and exposure—the same features used by VRS. Therefore, high metric scores reflect construct consistency with the SSVC rubric rather than causally independent evidence of breach prevention. Environmental parameters ($N$, $A$) were assigned to reflect archetypal deployment profiles (e.g., edge gateway vs. internal server) rather than a specific organization's live telemetry. Mapping SSVC discrete outcomes into 4-level ordinal grades introduces additional discretization subjectivity.

**Baseline Information Asymmetry**: A critical threat to comparative baseline validity is information asymmetry. Baselines 1–4 (CVSS-only, EPSS-only, KEV-first, and Combo) operate exclusively on vulnerability-centric attributes ($C, E, K$). None of the baselines incorporate environmental deployment context ($N$, $A$). Because the SSVC decision tree requires exposure and mission impact to assign high-urgency tiers (Act/Attend), full VRS possesses a structural informational advantage over vulnerability-only baselines. Our ablation study isolates this effect: when environmental context is removed (`VRS No Context`), Spearman correlation drops to $\rho = 0.8782$, closely matching the unweighted combo baseline ($\rho = 0.8800$). This confirms that the observed performance gain over baselines is driven by environmental grounding rather than scoring formula artifacts.

**LLM Evaluation Scope and Guardrail Limits:** The empirical evaluation of our generative assistant (RQ3) combines a deterministic `MockLLM` CI fixture with single-pass `Llama-3.1-8B` inference rather than frontier commercial LLMs (e.g., GPT-4 or Claude 3.5). While this guarantees reproducible offline testing and verifies deterministic interception of numeric drift and known prompt injection signatures, it does not assess resistance against adaptive, multi-turn, or multilingual jailbreak strategies across frontier models, which remains future red-teaming work.

**External and Construct Validity**: Our evaluation uses 39 curated real CVEs and 2 synthetic records for SSVC construct alignment, alongside 500 real public CVEs for backlog scale analysis. In the 500-CVE corpus, all 25 KEV-listed items stem from the curated baseline, while 461 CVEs are sampled from a restricted 2023–2024 domain (`cves/2023/0xxx`, `cves/2024/0xxx`), none of which appeared in the KEV snapshot. Absence from CISA KEV denotes unobserved in federal reporting, not confirmed non-exploitation. Furthermore, EPSS probabilities model a rolling 30-day forecast and drift continuously; replicating without our frozen snapshot will introduce slight numerical variance.

## VII. Conclusion

This paper presented Vulture-AI, an evidence-grounded framework for automated vulnerability analysis and prioritization. By strictly decoupling quantitative risk scoring from generative narrative assistance, Vulture-AI mitigates CVSS alert fatigue while guarding generative triage assistance against tested indirect prompt injection and numerical hallucination patterns under controlled evaluation. The proposed Vulture Risk Score (VRS) integrates normalized CVSS severity, FIRST EPSS probabilities, CISA KEV catalog indicators, and environmental context with a deterministic tie-breaking hierarchy.

Evaluated on 39 real CVEs and 2 synthetic edge-case records against a CISA SSVC-inspired reference rubric, VRS achieved NDCG@10 of 1.0000, Precision@10 of 1.0000 on emergency actions, and Spearman correlation of 0.9488, outperforming CVSS-only (0.7563 NDCG, 0.6000 P@10) and unweighted baselines. Ablations confirmed environmental context adds 0.0706 in rank correlation. Results reflect construct alignment with SSVC triage principles; independent analyst validation and operational breach prediction remain future work. Future work will also extend Vulture-AI with distributed asynchronous worker queues and evaluate longitudinal SOC deployments across enterprise environments.

## References


[1] National Institute of Standards and Technology, "National Vulnerability Database (NVD)," 2026, [Online]. Available: https://nvd.nist.gov/. [Accessed: Oct. 14, 2026].

[2] FIRST, "Common Vulnerability Scoring System v3.1: Specification Document," Forum of Incident Response and Security Teams, Tech. Rep., 2019. [Online]. Available: https://www.first.org/cvss/v3.1/specification-document

[3] P. Mell, K. Scarfone, and S. Romanosky, "A complete guide to the common vulnerability scoring system version 2.0," *IEEE Security & Privacy*, vol. 5, no. 6, pp. 23–31, 2007.

[4] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit Prediction Scoring System (EPSS)," *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 1–17, 2021.

[5] Cybersecurity and Infrastructure Security Agency, "Binding Operational Directive 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities," https://www.cisa.gov/binding-operational-directive-22-01, 2021.

[6] ——, "Known Exploited Vulnerabilities Catalog," 2026, [Online]. Available: https://www.cisa.gov/known-exploited-vulnerabilities-catalog. [Accessed: Oct. 14, 2026].

[7] J. M. Spring, E. Hatlebakke, A. Householder, A. Manion, and D. Shick, "Prioritizing Vulnerability Response with a Stakeholder-Specific Vulnerability Categorization," Software Engineering Institute, Carnegie Mellon University, Tech. Rep. CMU/SEI-2020-TR-001, 2020.

[8] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISEC)*, 2023, pp. 79–90.

[9] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W.-t. Yih, T. Rocktäschel, S. Riedel, and D. Kiela, "Retrieval-augmented generation for knowledge-intensive NLP tasks," in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, 2020, pp. 9459–9474.